

V.E.R.A.

Privacy- en Securitypakket

Documentatiepakket ter ondersteuning van de organisatorische en juridische stappen bij het verwerken van (bijzondere) persoonsgegevens: privacyverklaring, DPIA, verwerkersovereenkomsten-checklist en een beveiligingsoverzicht voor de Functionaris Gegevensbescherming.

Dit zijn sjablonen op basis van de technische inrichting van V.E.R.A. — geen juridisch advies, en geen vervanging voor beoordeling door de eigen FG.

Inhoudsopgave

1. Beveiligingsmaatregelen — overzicht voor FG / security officer
2. Privacyverklaring V.E.R.A. (sjabloon)
3. DPIA-sjabloon: V.E.R.A.
4. Checklist verwerkersovereenkomsten (VWO's)

1. Beveiligingsmaatregelen — overzicht voor FG / security officer

Dit document vat de technische beveiligings- en privacymaatregelen van V.E.R.A. **niet- technisch** samen, voor gebruik bij een DPIA-beoordeling, FG-toetsing of security-audit. Voor de volledige technische onderbouwing en broncodeverwijzingen, zie `README.md` hoofdstuk 4 ("Privacy & security").

Privacy-by-design

Maatregel	Wat betekent dit in de praktijk?
Tijdelijke dossierinhoud	Aantekeningen en verslagteksten worden automatisch en onomkeerbaar verwijderd zodra een rapport verloopt (standaard na 30 dagen); alleen niet-herleidbare metadata blijft over.
Geen losse gevoelige velden	Er bestaan geen aparte databasevelden voor BSN, geboortedatum e.d. — dergelijke gegevens kunnen alleen in de tijdelijke, vrije brontekst voorkomen.
Automatisch gegenereerde titels	Rapporttitels bevatten nooit door een medewerker getypte (mogelijk herleidbare) tekst.
Zelfbediening	Medewerkers kunnen eigen rapporten en accountgegevens zelf en direct verwijderen, zonder tussenkomst van beheer.

Toegangsbeveiliging

Maatregel	Wat betekent dit in de praktijk?
Wachtwoorden	Nooit leesbaar opgeslagen (industriestandaard hashing, bcrypt).
Sessies	Verlopen automatisch na 12 uur; sessiecookie is niet uitleesbaar door JavaScript en alleen over HTTPS in productie.
Organisatie-isolatie	Een medewerker kan uitsluitend rapporten van de eigen organisatie zien of bewerken — technisch afgedwongen op elke bevraging, niet alleen in de gebruikersinterface.
Anti-enumeratie	Het systeem laat nooit aan een aanvaller zien of een e-mailadres of rapport-ID wél bestaat maar ontoegankelijk is, versus niet bestaat.
Misbruikpreventie	Herhaalde onjuiste inlogpogingen worden automatisch vertraagd/geblokkeerd.

Betrouwbaarheid van AI-gegenereerde tekst

Maatregel	Wat betekent dit in de praktijk?
Zero-fabrication-ontwerp	De AI mag uitsluitend herformuleren/structureren wat in de brontekst staat; het mag nooit informatie verzinnen die daar niet in staat.

Maatregel	Wat betekent dit in de praktijk?
Verplichte menselijke controle	Elk hoofdstuk moet door de medewerker gecontroleerd worden voordat het rapport geëxporteerd kan worden; ontbrekende informatie wordt expliciet gemarkeerd in plaats van stilzwijgend aangevuld.
Geen training op cliëntgegevens	De AI-leverancier is geconfigureerd om de verstuurde tekst niet te bewaren of te gebruiken voor het trainen van modellen.

Logging en verantwoording

Maatregel	Wat betekent dit in de praktijk?
Audit-logging	Belangrijke acties (bv. rapport aangemaakt/geëxporteerd) worden gelogd met wie, wat en wanneer — nooit met de inhoud van het dossier zelf.
IP-adressen	Worden nooit in leesbare vorm opgeslagen, alleen als onomkeerbare hash (voor het detecteren van patronen, niet voor het herleiden van een individu).
Foutafhandeling	Technische foutmeldingen (bv. databasefouten) worden nooit aan de gebruiker getoond — alleen server-side gelogd.

Beveiligde infrastructuur

Maatregel	Wat betekent dit in de praktijk?
Beveiligde HTTP-headers	Beschermen tegen veelvoorkomende webaanvallen (clickjacking, content-sniffing, etc.).
Server-side AI-sleutel	De sleutel voor de AI-leverancier is nooit zichtbaar voor de browser of opgeslagen in de database.
Invoerlimieten	Bestandsgrootte, aantal bestanden en tekstlengte zijn begrensd om misbruik en overbelasting te voorkomen.

Bekende openstaande punten (zie ook README.md §9)

Deze punten zijn **bewust nog niet** onderdeel van de huidige MVP-oplevering en vereisen een organisatorische of aanvullende technische stap vóór gebruik met echte cliëntgegevens:

- Verwerkersovereenkomsten met AI-leverancier, database- en hostingpartij.
- Formele DPIA-goedkeuring door de FG.
- Tweefactorauthenticatie (2FA).
- Fijnmaziger rollen-/rechtenmodel binnen een organisatie.
- Onafhankelijke penetratietest.
- Aansluiting van logging op het beveiligingsmonitoringsproces van de organisatie.

Zie `docs/privacy-security/dpia-sjabloon.md` en `docs/privacy-security/vwo-checklist.md` voor de bijbehorende actiepunten.

2. Privacyverklaring V.E.R.A. (sjabloon)

Let op — dit is een sjabloon, geen juridisch document. De tekst is gebaseerd op hoe V.E.R.A. technisch met gegevens omgaat (zie `README.md`, hoofdstuk 4 en de map `docs/privacy-security/`), maar moet vóór publicatie worden gecontroleerd en aangevuld door de Functionaris Gegevensbescherming (FG) van de organisatie die V.E.R.A. gebruikt. Vervang alle tekst tussen [haakjes].

Privacyverklaring [naam organisatie/gemeente] — V.E.R.A.

Laatst bijgewerkt: [datum]

1. Wie is verantwoordelijk?

[Naam organisatie], gevestigd te [plaats], is verwerkingsverantwoordelijke voor de persoonsgegevens die worden verwerkt bij het gebruik van V.E.R.A. (Verslag- en Rapportage Assistent). Vragen over deze verklaring kunnen worden gesteld aan de Functionaris Gegevensbescherming: [naam/contactgegevens FG].

2. Wat is V.E.R.A. en welke gegevens verwerkt het?

V.E.R.A. helpt professionals (bijvoorbeeld jeugdconsulenten) om aantekeningen en evaluaties om te zetten in een gestructureerd conceptverslag. Daarbij worden de volgende categorieën gegevens verwerkt:

- **Accountgegevens van medewerkers:** naam, e-mailadres, gehasht wachtwoord.
- **Dossierinhoud (tijdelijk):** de brontekst/aantekeningen die een medewerker invoert of

als `.docx`-bestand uploadt, en de daaruit gegenereerde hoofdstukteksten. Dit kan bijzondere persoonsgegevens van cliënten bevatten (bijvoorbeeld gezondheid, minderjarigen, sociale/justitiële gegevens), afhankelijk van wat de medewerker invoert.

- **Rapportmetadata (permanent):** vakgebied, documenttype, status, hoofdstuktelers en

tijdstempels. Deze metadata bevat **nooit** cliëntgegevens — rapporttitels worden automatisch gegenereerd uit documenttype en datum, nooit uit vrije tekst.

- **Technische/beveiligingsgegevens:** audit-logs (actie, tijdstip, gebruiker, een eenrichtings-hash van het IP-adres — nooit het IP zelf, nooit dossierinhoud).

3. Waarvoor gebruiken we deze gegevens?

Uitsluitend om medewerkers te ondersteunen bij het opstellen van conceptverslagen binnen hun functie, en om de dienst veilig en betrouwbaar te laten werken (authenticatie, misbruikpreventie, audit-logging).

Gegevens worden niet gebruikt voor profilering, geautomatiseerde besluitvorming over cliënten, of enig ander doel.

4. Wie heeft toegang / met wie delen we gegevens?

- **Medewerkers** zien uitsluitend rapporten van hun eigen organisatie

(organisatie-isolatie, technisch afgedwongen op elke databasebevraging).

- **AI-verwerking:** de brontekst wordt voor het genereren van het conceptverslag

verstuurd naar [naam AI-leverancier, bv. OpenAI], uitsluitend server-side, met `store: false` (de leverancier bewaart de invoer niet voor eigen doeleinden) en zonder gebruik van externe tools/websearch door het model. Zie de verwerkersovereenkomst met deze leverancier (bijlage bij deze verklaring / `docs/privacy-security/vwo-checklist.md`).

- **Hostingpartijen:** de database wordt gehost bij [Supabase] en de applicatie draait bij

[Render]. Met beide partijen is een verwerkersovereenkomst vereist.

- Gegevens worden niet verkocht of gedeeld met derden voor commerciële doeleinden.

5. Hoe lang bewaren we gegevens?

- Dossierinhoud (brondocumenten en hoofdstukteksten) wordt bewaard tot een rapport

verloopt: standaard [REPORT_RETENTION_DAYS, default 30] dagen na aanmaken. Daarna wordt de inhoud automatisch en onomkeerbaar verwijderd door een geautomatiseerd opschoonproces; alleen de metadata (zie hierboven) blijft bestaan.

- Deze bewaartermijn is een technische default uit de MVP-oplevering en moet nog worden

afgesteld met het archiveringsbeleid van de organisatie (zie DPIA-sjabloon).

- Wachtwoord-resettokens zijn maximaal 1 uur geldig en worden nooit in leesbare vorm opgeslagen.

6. Hoe beveiligen we de gegevens?

Zie het beveiligingsoverzicht ([docs/privacy-security/beveiligingsmaatregelen-overzicht.md](#)) voor een niet-technische samenvatting, en [README.md](#) hoofdstuk 4 voor het volledige technische overzicht (versleuteling van wachtwoorden, CSRF-bescherming, toegangscontrole per organisatie, audit-logging, beveiligde HTTP-headers, etc.).

7. Wat zijn de rechten van betrokkenen?

Clënten van wie gegevens (mogelijk) in een conceptverslag voorkomen, hebben op grond van de AVG recht op inzage, correctie, verwijdering, beperking en bezwaar. Verzoeken hierover verlopen via de reguliere klachten-/verzoekprocedure van [naam organisatie], niet rechtstreeks via V.E.R.A. — het systeem heeft geen apart cliëntportaal.

Medewerkers kunnen hun eigen accountgegevens en rapporten te allen tijde zelf verwijderen via het account-menu in de applicatie ([DELETE /api/account/data](#) voor alle eigen rapporten, of per rapport).

8. Klachten

Een betrokkene die een klacht heeft over de verwerking van zijn/haar gegevens, kan zich wenden tot de FG van [naam organisatie] en heeft daarnaast het recht een klacht in te dienen bij de Autoriteit Persoonsgegevens.

Dit sjabloon dekt geen juridisch advies. Laat deze verklaring beoordelen door de FG en/of juridische afdeling voordat deze wordt gepubliceerd.

3. DPIA-sjabloon: V.E.R.A.

Dit sjabloon volgt de structuur die het [DPIA-model van de Autoriteit Persoonsgegevens / NOREA](#) gebruikelijk hanteert. De vakjes met [...] moeten door de organisatie zelf worden ingevuld; de rest is voor-ingevuld op basis van hoe V.E.R.A. daadwerkelijk is gebouwd (zie [README.md](#) hoofdstuk 3-4 voor de onderliggende techniek). Dit vervangt geen formele DPIA-beoordeling door de FG.

1. Beschrijving van de verwerking

Wat: V.E.R.A. structureert vrije aantekeningen/evaluaties van een professional (bijvoorbeeld een jeugdconsulent) tot een conceptverslag volgens een vast format (hoofdstukstructuur), met behulp van een taalmodel (AI). De professional controleert en bewerkt het concept vóór export naar Word.

Waarom nodig: het documenttype (bv. "Onderzoeksverslag jeugdzorg") bevat per definitie bijzondere persoonsgegevens (gezondheid, minderjarigen, mogelijk strafrechtelijke/ justitiële gegevens) van cliënten. Verwerking van bijzondere persoonsgegevens op grote schaal, en de inzet van een geautomatiseerd taalmodel daarbij, vereist onder de AVG (art. 35) een DPIA.

Betrokkenen: cliënten wier gegevens in de brontekst kunnen voorkomen; medewerkers (accounts) die de applicatie gebruiken.

Verwerkingsdoel: ondersteuning bij het opstellen van conceptverslagen; geen profilering of geautomatiseerde besluitvorming over cliënten (de AI genereert uitsluitend een concepttekst op basis van wat de medewerker zelf invoert — "zero-fabrication": het model verzint nooit informatie die niet in de brontekst staat, en markeert ontbrekende informatie expliciet in plaats van deze aan te vullen).

Betrokken systemen: V.E.R.A.-applicatie (Next.js, gehost op [Render]), PostgreSQL- database (gehost op [Supabase]), AI-leverancier ([OpenAI], Responses API), e-mailleverancier voor wachtwoordreset ([Resend], optioneel).

2. Noodzaak en evenredigheid

- **Dataminimalisatie:** er zijn bewust geen aparte databasekolommen voor gevoelige

identifiers (BSN, geboortedatum, volledig adres). Dergelijke gegevens kunnen alleen voorkomen binnen de vrije brontekst, die tijdelijk is (zie §4).

- **Doelbinding:** de brontekst wordt uitsluitend gebruikt om het conceptverslag te

genereren; er is geen secundair gebruik (geen training van modellen op de data — de AI-aanroep gebruikt `store: false`, dus de leverancier bewaart de invoer niet).

- **Alternatieven overwogen:** [in te vullen — bv. volledig handmatig verslagleggen, on-premise taalmodel]. Afweging: [in te vullen].

3. Risico's voor betrokkenen

#	Risico	Waarschijnlijkheid	Impact	Genomen maatregel
1	Onbevoegde toegang tot dossiers van een andere organisatie/gemeente	Laag	Hoog	Organisatie-isolatie op elke databasequery; IDOR-preventie met identieke generieke 404 bij niet-bestaand of niet-eigen rapport (getest, <code>tests/authz-idor.test.ts</code>)

#	Risico	Waarschijnlijkheid	Impact	Genomen maatregel
2	Datalek bij de AI-leverancier	Laag–gemiddeld	Hoog	<code>store: false</code> , geen tools/websearch, server-side only API-key, verwerkersovereenkomst vereist vóór productiegebruik (zie VWO-checklist)
3	Te lange bewaring van gevoelige brontekst	Gemiddeld (zonder maatregel)	Gemiddeld–hoog	Automatische retentie-purge (standaard 30 dagen), alleen metadata blijft daarna over
4	Herleidbare informatie in rapporttitel/permanente metadata	Laag	Gemiddeld	Titels altijd automatisch gegenereerd (documenttype + datum), nooit uit vrije tekst; het vrije "eigen referentie"-veld wordt behandeld als tijdelijke inhoud en dus ook geleeft bij purge
5	Wachtwoord-brute-force / credential stuffing	Gemiddeld	Gemiddeld	bcrypt (12 rounds), rate limiting op login/registratie, generieke foutmeldingen (geen account-enumeratie)
6	AI "verzint" informatie die in het verslag als feit terechtkomt	Gemiddeld (zonder maatregel)	Hoog	Zero-fabrication-ontwerp: elke bewering moet herleidbaar zijn tot de brontekst; ontbrekende informatie wordt gemarkeerd i.p.v. aangevuld; medewerker controleert en bewerkt elk hoofdstuk vóór export (stap 4 van de workflow)
7	Onvoldoende toegangsbeheer binnen een organisatie (iedereen is beheerder)	Gemiddeld	Gemiddeld	Bekend MVP-gat, zie pre-productiechecklist in <code>README.md</code> §9 — rollenmodel/uitnodigingsflow nog uit te breiden
8	Ontbreken van 2FA	Gemiddeld	Gemiddeld	Nog niet geïmplementeerd — zie pre-productiechecklist
9	[Aanvullend risico specifiek voor eigen organisatie]	[...]	[...]	[...]

4. Bewaartermijnen

Gegevenscategorie	Bewaartermijn	Onderbouwing
Dossierinhoud (brontekst, hoofdstukteksten)	REPORT_RETENTION_DAYS, default 30 dagen na aanmaken rapport	Technische MVP-default; moet worden afgestemd met archiefwet/gemeentelijk beleid — zie actiepunt in §6
Rapportmetadata (vakgebied, status, tijdstempels)	Onbeperkt (bevat geen cliëntgegevens)	Nodig voor verantwoording/statistiek zonder privacyrisico
Accountgegevens medewerker	Zolang het account actief is	Noodzakelijk voor toegang tot de dienst
Audit-logs	[in te vullen — huidige implementatie kent geen automatische purge van audit-logs]	Beveiligingsmonitoring/verantwoording
Wachtwoord-resettoken	1 uur, of tot gebruikt	Beperkt misbruikvenster

5. Betrokken verwerkers en doorgifte

Verwerker	Rol	Verwerkersovereenkomst nodig?	Doorgifte buiten EER?
[OpenAI / gekozen AI-leverancier]	Verwerkt brontekst om conceptverslag te genereren	Ja — nog niet afgesloten	[Controleren: regio van verwerking/opslag van de gekozen leverancier]
[Supabase]	Hosting PostgreSQL-database	Ja — nog niet afgesloten	[Controleren: welke regio is gekozen bij het aanmaken van het Supabase-project]
[Render]	Hosting webservice	Ja — nog niet afgesloten	[Controleren: gekozen regio]
[Resend] (optioneel, wachtwoordreset)	Verzenden van resetlink-e-mails	Ja, indien geactiveerd	[Controleren]

6. Actiepunten uit deze DPIA

- ☐ Verwerkersovereenkomsten afsluiten met alle bovenstaande partijen (zie [docs/privacy-security/vwo-checklist.md](#)).
- ☐ Bewaartermijn (REPORT_RETENTION_DAYS) formeel vaststellen i.o.m. archiefbeleid.
- ☐ Rollenmodel binnen een organisatie uitbreiden (niet iedereen beheerder).
- ☐ 2FA toevoegen vóór productiegebruik met bijzondere persoonsgegevens.
- ☐ Onafhankelijke penetratietest/security-review laten uitvoeren.
- ☐ Beoordeling en formele goedkeuring door de FG vastleggen (datum, naam, versie van deze DPIA).
- ☐ Regio van gegevensverwerking bij AI-leverancier, Supabase en Render bevestigen en vastleggen (doorgifte buiten de EER kan aanvullende waarborgen vereisen).

7. Beoordeling en akkoord

Rol	Naam	Datum	Akkoord
Opsteller	[...]	[...]	
Functionaris Gegevensbescherming	[...]	[...]	

Rol	Naam	Datum	Akkoord
Proceseigenaar / verwerkingsverantwoordelijke	[...]	[...]	

4. Checklist verwerkersovereenkomsten (VWO's)

V.E.R.A. maakt gebruik van externe partijen die (mogelijk) persoonsgegevens verwerken namens de organisatie die V.E.R.A. inzet. Voor elk van deze partijen is, vóórdat er met echte cliëntgegevens wordt gewerkt, een verwerkersovereenkomst (VWO) op grond van art. 28 AVG vereist. Deze checklist somt op welke partijen dat zijn, wat ze precies verwerken, en waar in de configuratie dat terug te vinden is.

Verwerker	Wat verwerkt deze partij?	Waar in de code/config?	VWO afgesloten?
AI-leverancier (standaard: OpenAI, <code>OPENAI_MODEL</code>)	Ontvangt de brontekst (aantekeningen/evaluaties) om het conceptverslag te structureren. Uitsluitend server-side aangeroepen, met <code>store: false</code> (leverancier bewaart de invoer niet).	<code>src/lib/ai/openaiProvider.ts</code> , <code>src/lib/ai/provider.ts</code>	[]
Database-hosting (standaard: Supabase)	Slaat alle persistente data op: accounts, rapporten, bronnen, hoofdstukken, audit-logs.	<code>DATABASE_URL</code> / <code>DIRECT_URL</code> in <code>.env</code> , <code>prisma/schema.prisma</code>	[]
Applicatie-hosting (Render)	Draait de webservice; heeft in-memory/runtime toegang tot alle verwerkte data en omgevingsvariabelen (incl. geheimen).	<code>render.yaml</code>	[]
E-mailleverancier (Resend, optioneel)	Verzendt wachtwoord-resetlinks naar het e-mailadres van de medewerker. Geen dossierinhoud. Alleen actief als <code>RESEND_API_KEY</code> is ingesteld — anders wordt de resetlink alleen gelogd.	<code>src/lib/email/passwordResetEmail.ts</code> , <code>RESEND_API_KEY</code>	[] N.v.t. zolang <code>RESEND_API_KEY</code> leeg is

Aandachtspunten per overeenkomst

Neem in elke VWO in ieder geval het volgende op (of controleer dat de standaard-VWO van de leverancier dit al dekt):

- **Doelbinding:** gegevens mogen uitsluitend worden gebruikt om de afgesproken dienst te

leveren, niet voor eigen doeleinden van de verwerker (bv. modeltraining). Controleer expliciet of de gekozen AI-leverancier en het gekozen model/abonnement dit garanderen, naast de `store: false`-instelling die deze applicatie al afdwingt.

- **Subverwerkers:** welke subverwerkers zet de partij zelf in, en is daar toestemming

voor nodig?

- **Locatie van verwerking/opslag:** binnen de EER, of is er sprake van doorgifte

daarbuiten? Zo ja: op basis van welke waarborg (bv. EU Standard Contractual Clauses)?

- **Bewaartermijn bij de verwerker:** hoe lang bewaart de verwerker de data (bv.

request-logs bij de AI-leverancier), en is dat in lijn met het eigen retentiebeleid (`REPORT_RETENTION_DAYS`)?

- **Meldplicht datalekken:** binnen welke termijn meldt de verwerker een datalek aan de

organisatie? (Nodig om zelf binnen 72 uur bij de AP te kunnen melden.)

- **Audit-/inzagerecht:** heeft de organisatie het recht om de naleving te controleren (zelf, of via een certificering zoals ISO 27001/SOC 2 van de verwerker)?
- **Einde van de overeenkomst:** wordt data verwijderd of geretourneerd bij beëindiging?

Status

- [] Alle bovenstaande VWO's zijn afgesloten en gearhiveerd (bv. bij de FG of inkoopafdeling).
- [] De gekozen regio's voor AI-leverancier, database en hosting zijn gecontroleerd en vastgelegd in de DPIA ([docs/privacy-security/dpia-sjabloon.md](#), §5).
- [] Deze checklist is opnieuw doorlopen bij elke wijziging van leverancier (bv. een andere AIProvider-implementatie, zie [src/lib/ai/index.ts](#)).